

푸른돌소프트 ADR-0031

내부 서비스 간 인증 방식

상태

제안 (2026-08-05). 9월 아키텍처 회의에서 채택 여부를 정한다.

문제

내부 서비스 11개가 서로를 부를 때 공유 비밀키 한 개를 쓴다. 키는 설정 저장소에 있고 모든 서비스가 같은 값을 읽는다. 키를 바꾸려면 11개를 동시에 재기동해야 하므로 3년째 바꾸지 못했다. 어느 서비스가 어느 서비스를 불렀는지도 구분되지 않아 장애 분석에서 호출 주체를 특정하지 못한 적이 있다.

선택지

안	요약	이관 비용	위험
A	서비스별 개별 키 발급	낮음 (약 30인시)	키 개수 증가, 회전 절차 여전히 수동
B	단기 토큰 발급 서버 도입	중간 (약 130인시)	발급 서버가 단일 장애점
C	상호 TLS	높음 (약 275인시)	인증서 만료 운영 부담

제안

B를 택하되 발급 서버를 2대 이상으로 두고, 토큰 수명을 15분으로 잡는다. 발급 서버 장애 시에는 기존 공유키를 30일간 유효한 비상 경로로 남긴다. 비상 경로는 사용 시 즉시 알람이 울리게 한다.

고려하지 않은 것

- 외부 상용 인증 제품 도입. 예산 배정이 없다.
- 서비스 메시 도입. 인증만을 위해 도입하기에는 운영 부담이 크다.

되돌리기

적용 후 3개월 안에 발급 서버로 인한 장애가 2회 이상 발생하면 A 안으로 후퇴한다. 이 조건은 채택 시 함께 기록한다.